CYBERSECURITY AVANZATA · LEZIONI 1-8

Verifica di cybersecurity avanzata: soluzioni e griglia

Risposte corrette, punteggi e indicazioni di correzione. Totale 100 punti; voto in decimi = punti ÷ 10, arrotondato al mezzo voto (60 punti = 6). Nei calcoli: risultato corretto senza procedimento = metà dei punti; procedimento corretto con un errore di calcolo = punti pieni meno 1.

1. Scelta multipla · 18 punti

Dom.	Risposta corretta	Punti	Note
a	**memorizzato (stored)**	3	Resta nel database e colpisce ogni visitatore.
b	**dare hash diversi a password uguali e rendere inutili le tabelle precalcolate**	3	Il salt non è segreto e non rallenta: rallentano le iterazioni.
c	**dimostrare che il server è davvero quello del dominio**	3	La cifratura usa chiavi di sessione concordate nell'handshake.
d	**la chiave privata è legata al dominio del sito vero e non lo lascia mai**	3	Su un sito clone il browser non offre la passkey.
e	**il dominio riceve i report ma non chiede di bloccare nulla**	3	Lo spam è quarantine, il rifiuto è reject.
f	`tls.handshake.type == 1`	3	

2. Vero o falso · 12 punti (1,5 ciascuna)

N.	V/F	Motivo
1	**F**	Il CVSS misura la gravità, non la probabilità di sfruttamento (per quella: KEV, EPSS).
2	**F**	Un hash non ha chiave e non si inverte: si può solo indovinare l'input.
3	**V**	Il certificato non garantisce più l'identità del server.
4	**F**	È solo codificato in Base64url: chiunque lo legge. La firma impedisce di modificarlo.
5	**V**	
6	**V**	Visibili IP, nome del sito (SNI), tempi e dimensioni.
7	**F**	Intercettare comunicazioni altrui è reato (art. 617-quater c.p.) anche sulla propria rete.
8	**V**	Cambia la data di creazione.

3. Leggere un avviso di sicurezza · 10 punti

a) **AV:N** si attacca da remoto, via rete; **PR:N** l'attaccante non ha bisogno di un account; **UI:R** serve un'azione della vittima, per esempio aprire un link (1 punto ciascuno). b) **Media** (4,0–6,9) (2 punti). c) KEV = falla **già sfruttata davvero**: va corretta subito, prima di falle con punteggio più alto ma non

sfruttate (2 punti). d) Da fare: **avvisare in privato lo sviluppatore del plugin (o il CERT/CSIRT), dare un tempo ragionevole per la correzione, documentare con prove minime**; da non fare: **pubblicarla prima della correzione, sfruttarla su siti altrui, chiedere soldi in cambio del silenzio** (1 punto per voce, max 3).

4. XSS e CSRF nel codice · 12 punti

a) Lo script viene scritto nella pagina e **eseguito nel browser dell'ospite, sul dominio del sito**: può leggere dati della pagina, compiere azioni a suo nome, mostrare un falso modulo. È un **XSS riflesso** (2 + 1). b) Codificare l'output HTML: `<b>Anna</b>`, cioè `<` e `>` (e anche `&`, `"`, `'`) diventano entità e il browser li mostra come testo (3 punti; 2 se dice solo "filtrare" senza mostrare la codifica). c) `Content-Security-Policy: script-src 'self'` (accettare `default-src 'self'`) (2 punti). d) Esempio: un sito qualsiasi contiene `<img src="https://ilglicine.example/annulla?id=42">`; il browser dell'ospite collegato manda la richiesta con il cookie e la prenotazione viene annullata (2 punti). Difese (1 punto ciascuna, max 2): **azioni che cambiano dati solo con POST, token anti-CSRF nel modulo, cookie SameSite=Lax o Strict, conferma dell'utente**.

5. Le password degli ospiti · 12 punti

a) 62^8 = **$2{,}18 \times 10^{14}$** (2 punti). b) $2{,}18 \times 10^{14} \div 10^{10}$ = 21 834 s ≈ **6 ore** (3 punti). c) 21 834 s × 600 000 ≈ $1{,}31 \times 10^{10}$ s ÷ $3{,}16 \times 10^{7}$ ≈ **415 anni** (3 punti; accettare 410–420). d) Senza salt: **due hash identici**, quindi indovinata una, l'altra è nota; con il salt: **hash diversi**, ogni password va attaccata da sola (2 punti). e) Ogni carattere in più moltiplica le combinazioni per il numero di simboli (crescita esponenziale); i simboli strani aumentano poco la base e spesso finiscono in schemi prevedibili (**la lunghezza è all'esponente**) (2 punti).

6. Il token dell'API · 10 punti

a) La **firma HMAC-SHA256** di header e payload, calcolata con il **segreto del server** (2 punti). b) **401 Unauthorized**: il server ricalcola la firma sul payload modificato, non coincide con quella ricevuta e il token è rifiutato (3 punti). c) **403 Forbidden**: 401 = non so chi sei o il token non è valido; 403 = so chi sei, ma non hai il permesso (1 + 2). d) Un token rubato **vale solo fino alla scadenza**, e un JWT non si può revocare facilmente prima (2 punti).

7. Chi può fingersi il B&B? · 8 punti

a) ilglicine.example **scoperto**: niente DMARC, e SPF con `~all` (soft fail). agenzia-viaggi.example **protetto**: DMARC `p=reject` con report (1,5 + 1,5). b) In ordine (1 punto ciascuno): **1. pubblicare DMARC `p=none` con `rua=` e leggere i report; 2. sistemare SPF (`-all`) e attivare DKIM per tutti i servizi che inviano posta; 3. passare a `p=quarantine` e poi `p=reject`**. Saltare subito a reject senza report: 2 punti su 3. c) DMARC protegge **solo il dominio esatto** `ilglicine.example`; il dominio sosia è un altro dominio, legittimamente configurato dal truffatore, e le sue mail passano i controlli (2 punti).

8. Che cosa passa sulla rete · 10 punti

a) **E, B, D, A, G, C, F** (3 punti; 2 se c'è un solo scambio). b) **server_name (SNI)** (1 punto). c) Visibili: **indirizzi IP e porte, nome del sito nello SNI, richiesta DNS, tempi e dimensioni dei pacchetti**; nascosti: **percorso, parametri, header, cookie, contenuto della pagina** (1,5 + 1,5). d) Nella richiesta POST si leggono **utente e password in chiaro** (2 punti); rimedio: **HTTPS con certificato valido (e HSTS), la porta 80/8080 al massimo reindirizza** (1 punto).

9. Dopo l'incidente · 8 punti

a) **La RAM**, perché è più volatile: allo spegnimento si perdono processi, connessioni e chiavi (ordine di volatilità, RFC 3227). b) Il file è stato **copiato su quel PC** da un altro supporto il 12/03 alle 21:14: la creazione è l'arrivo sul disco, la modifica viene dall'originale. c) Dimostra che **la copia è identica bit per**

bit all'originale in quel momento; non dimostra chi ha scritto i file, che cosa contengono né che cosa è successo prima dell'acquisizione. d) Il **registro di ogni passaggio di mano del reperto** (chi, quando, che cosa, hash); senza, non si può escludere che la prova sia stata alterata. 2 punti ciascuna, 1 se incompleta.